REPORT DI ANALISI CYBERSECURITY: Rilevazione IOC e Analisi Minacce

Data: 30 Aprile 2026

Oggetto: Analisi cattura traffico di rete e valutazione minacce phishing (CSIRT)

---

1. Analisi Tecnica della Cattura Wireshark

1.1 Identificazione degli IOC (Indicators of Compromise)

Dall'analisi della cattura di rete effettuata tra l'host sorgente **192.168.200.100** e la destinazione **192.168.200.150**, sono stati identificati i seguenti indicatori critici:

- **Scansione Massiva di Porte (TCP SYN Scan):** Si osserva un volume anomalo di pacchetti SYN inviati in sequenza rapidissima verso un range esteso di porte (es. 21, 22, 23, 25, 80, 111, 443, 445).
- **Risposte RST/ACK (Connection Refused):** L'elevata presenza di pacchetti di reset evidenziati in rosso indica che l'attaccante sta tentando di connettersi a servizi non attivi, comportamento tipico dei tool di *network discovery*.
- **Target Vulnerabile:** L'host destinazione si identifica tramite protocollo BROWSER come **"METASPLOITABLE"**, confermando che l'obiettivo è una macchina deliberatamente vulnerabile.
- **Tentativi su Porte Critiche:** Sono stati registrati tentativi di connessione mirati verso servizi sensibili: **445 (SMB)**, **22 (SSH)**, **23 (Telnet)** e **21 (FTP)**.

1.2 Ipotesi sui Vettori di Attacco

In base agli IOC rilevati, si ipotizza il seguente scenario:

- **Fase di Ricognizione:** L'attaccante sta utilizzando un tool automatizzato (probabilmente **Nmap**) per mappare i servizi attivi.
- **Vettore di sfruttamento:** L'attaccante mira a sfruttare vulnerabilità note nei protocolli obsoleti (SMB, Telnet, FTP) presenti sulla macchina Metasploitable.
- **Origine:** Trattandosi di IP della stessa sottorete, l'attacco è di tipo **Insider Threat** o conseguenza di un movimento laterale riuscito.

1.3 Azioni di Mitigazione Consigliate

- **Isolamento:** Disconnettere immediatamente l'host 192.168.200.100 dalla rete.
- **Network Hardening:** Disabilitare i protocolli non necessari (Telnet, FTP) e applicare le patch di sicurezza sui servizi SMB.
- **Monitoraggio:** Configurare regole sull'IDS per bloccare scansioni SYN provenienti da un singolo IP verso porte multiple in tempi ristretti.

2. Approfondimento CSIRT Italia e Prevenzione Phishing

2.1 Il CSIRT Italia (ACN)

Il **CSIRT Italia** (Computer Security Incident Response Team) opera presso l'**Agenzia per la Cybersicurezza Nazionale (ACN)**. È l'organo tecnico incaricato di monitorare, analizzare e rispondere agli incidenti informatici a livello nazionale.

Compiti principali:

1. Monitoraggio continuo delle minacce cibernetiche nazionali.
2. Emissione di allerte e bollettini per la protezione di cittadini e imprese.
3. Coordinamento della risposta agli incidenti critici.

2.2 Analisi Allerta: Campagna Phishing "Trenitalia"

L'allerta **AL03/240322** descrive una campagna di *smishing* che promette premi (Gift Card) tramite un falso sondaggio Trenitalia. L'obiettivo è il furto di dati personali e credenziali di pagamento.

2.3 Strategia di Protezione Organizzativa

Per proteggere l'organizzazione da questa specifica campagna e da minacce simili, si raccomanda:

- **Security Awareness Training:** Istruire il personale a non cliccare su link provenienti da SMS sospetti e a verificare sempre il dominio ufficiale (es. trenitalia.com vs domini contraffatti).
- **Filtri Web e DNS:** Implementare sistemi di filtraggio per bloccare preventivamente la navigazione verso URL malevoli segnalati dal CSIRT.
- **Autenticazione a due fattori (MFA):** Implementare l'MFA su tutti gli accessi aziendali per neutralizzare l'efficacia del furto di credenziali.
- **Procedura di Reporting:** Incoraggiare i dipendenti a segnalare tempestivamente al reparto IT ogni comunicazione sospetta ricevuta sui dispositivi aziendali.